

# ■■ S3 EXPOSURE SCAN REPORT

Client: FinVault Technologies Ltd

Industry: Fintech / SaaS

AWS Account: 234567890123

Scan Date: June 19, 2026 22:42 UTC

Buckets Scanned: 8

---

**0/100** — CRITICAL RISK

Total Findings: 51 | Critical: 12 High: 31 Medium: 8 Low: 0

---

Consultant: Your Name

Cloud Security Consultant

hello@yoursite.com

AWS SAA Certified | ISO 27001 | NIST | GDPR

■ **CONFIDENTIAL** — For authorized recipients only

# Table of Contents

---

- 1. Executive Summary
- 2. Buckets Scanned — Overview
- 3. Security Check Results — Bucket Matrix
- 4. Detailed Findings
- 5. Remediation Roadmap
- 6. Appendix — Check Definitions

# 1. Executive Summary

This S3 Exposure Scan was conducted on the FinVault Technologies Ltd AWS environment on June 19, 2026. The scan assessed 8 S3 bucket(s) across 10 security checks covering public access, encryption, logging, resilience, access control, and data governance. 8 of 8 bucket(s) have at least one failing check. A total of 51 finding(s) were identified: 12 Critical, 31 High, 8 Medium, and 0 Low severity. The overall S3 security posture score is 0/100 — rated CRITICAL RISK.

|                                                                                                  |                                                                                                                                                                                                                       |          |    |      |    |        |   |     |   |       |    |
|--------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|----|------|----|--------|---|-----|---|-------|----|
| <div><div>0</div><div>out of 100</div><div>S3 SECURITY SCORE</div><div>CRITICAL RISK</div></div> | <div>Finding Breakdown</div> <table><tr><td>Critical</td><td>12</td></tr><tr><td>High</td><td>31</td></tr><tr><td>Medium</td><td>8</td></tr><tr><td>Low</td><td>0</td></tr><tr><td>Total</td><td>51</td></tr></table> | Critical | 12 | High | 31 | Medium | 8 | Low | 0 | Total | 51 |
| Critical                                                                                         | 12                                                                                                                                                                                                                    |          |    |      |    |        |   |     |   |       |    |
| High                                                                                             | 31                                                                                                                                                                                                                    |          |    |      |    |        |   |     |   |       |    |
| Medium                                                                                           | 8                                                                                                                                                                                                                     |          |    |      |    |        |   |     |   |       |    |
| Low                                                                                              | 0                                                                                                                                                                                                                     |          |    |      |    |        |   |     |   |       |    |
| Total                                                                                            | 51                                                                                                                                                                                                                    |          |    |      |    |        |   |     |   |       |    |

## 2. Buckets Scanned — Overview

| # | Bucket Name                      | Findings | Worst Sev | Status   |
|---|----------------------------------|----------|-----------|----------|
| 1 | finvault-prod-customer-documents | 9        | CRITICAL  | ✗ ISSUES |
| 2 | finvault-prod-database-backups   | 6        | CRITICAL  | ✗ ISSUES |
| 3 | finvault-prod-app-assets         | 3        | HIGH      | ✗ ISSUES |
| 4 | finvault-staging-uploads         | 8        | CRITICAL  | ✗ ISSUES |
| 5 | finvault-prod-audit-logs         | 1        | HIGH      | ✗ ISSUES |
| 6 | finvault-dev-test-data           | 8        | CRITICAL  | ✗ ISSUES |
| 7 | finvault-prod-invoices           | 8        | CRITICAL  | ✗ ISSUES |
| 8 | finvault-static-website          | 8        | CRITICAL  | ✗ ISSUES |

### 3. Security Check Results — Bucket Matrix

Each cell shows whether the bucket passed (✓) or failed (✗) each of the 10 security checks.

| Bucket                           | BPA    | ACL    | POL    | ENC    | TLS    | LOG    | VER    | MFA    | XAC    | LCY    |
|----------------------------------|--------|--------|--------|--------|--------|--------|--------|--------|--------|--------|
| finvault-prod-customer-documents | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✓ PASS | ✗ FAIL |
| finvault-prod-database-backups   | ✗ FAIL | ✓ PASS | ✓ PASS | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✓ PASS | ✗ FAIL | ✓ PASS | ✗ FAIL |
| finvault-prod-app-assets         | ✓ PASS | ✓ PASS | ✓ PASS | ✓ PASS | ✓ PASS | ✗ FAIL | ✓ PASS | ✗ FAIL | ✗ FAIL | ✓ PASS |
| finvault-staging-uploads         | ✗ FAIL | ✗ FAIL | ✓ PASS | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✓ PASS | ✗ FAIL |
| finvault-prod-audit-logs         | ✓ PASS | ✓ PASS | ✓ PASS | ✓ PASS | ✓ PASS | ✓ PASS | ✓ PASS | ✗ FAIL | ✓ PASS | ✓ PASS |
| finvault-dev-test-data           | ✗ FAIL | ✓ PASS | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✓ PASS | ✗ FAIL |
| finvault-prod-invoices           | ✗ FAIL | ✓ PASS | ✓ PASS | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL |
| finvault-static-website          | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✓ PASS | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✗ FAIL | ✓ PASS | ✗ FAIL |

- BPA — Block Public Access Disabled
- ACL — Bucket Publicly Accessible via ACL
- POL — Bucket Publicly Accessible via Policy
- ENC — No Default Encryption
- TLS — HTTP Access Allowed (No HTTPS Enforcement)

- LOG — Server Access Logging Disabled
- VER — Versioning Disabled
- MFA — MFA Delete Disabled
- XAC — Cross-Account Access in Bucket Policy
- LCY — No Lifecycle Policy Configured

4. Detailed Findings

|                                                                       |                                                                                                                                                                                  |          |
|-----------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| <b>[S3-001] Block Public Access Disabled</b> → finvault-dev-test-data |                                                                                                                                                                                  | CRITICAL |
| Bucket                                                                | finvault-dev-test-data                                                                                                                                                           |          |
| Category                                                              | Public Access                                                                                                                                                                    |          |
| What was found                                                        | BlockPublicAcls=False, IgnorePublicAcls=False, BlockPublicPolicy=False, RestrictPublicBuckets=False                                                                              |          |
| Description                                                           | The account-level or bucket-level S3 Block Public Access setting is not fully enabled. This safety net prevents accidental public exposure from any ACL or bucket policy change. |          |
| Impact                                                                | A single misconfigured ACL or bucket policy can expose data to the entire internet with no account-level guardrail to prevent it.                                                |          |
| Fix                                                                   | Enable all 4 Block Public Access settings at the account level in S3 > Block Public Access. Also enable at the bucket level for each bucket.                                     |          |
| Reference                                                             | AWS CIS Benchmark v1.5 — Control 2.1.5   PCI-DSS Requirement 1.3                                                                                                                 |          |

|                                                                                |                                                                                                                                                                                         |          |
|--------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| <b>[S3-003] Bucket Publicly Accessible via Policy</b> → finvault-dev-test-data |                                                                                                                                                                                         | CRITICAL |
| Bucket                                                                         | finvault-dev-test-data                                                                                                                                                                  |          |
| Category                                                                       | Public Access                                                                                                                                                                           |          |
| What was found                                                                 | Public policy statements: Action: s3:* (full access)                                                                                                                                    |          |
| Description                                                                    | The bucket policy contains a statement with Principal: '*' and no restrictive conditions, allowing any unauthenticated request to access bucket objects.                                |          |
| Impact                                                                         | Public read or write access to bucket objects without any authentication. More dangerous than ACL exposure as policies can grant write access to anonymous users.                       |          |
| Fix                                                                            | Review and remove all Principal: '*' statements. If public access is intentional (e.g. static website), restrict to specific actions (s3:GetObject only) and enable CloudFront instead. |          |
| Reference                                                                      | AWS CIS Benchmark v1.5 — Control 2.1.5   OWASP Cloud Security                                                                                                                           |          |

**[S3-001] Block Public Access Disabled** → finvault-prod-customer-documents**CRITICAL**

|                |                                                                                                                                                                                  |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-customer-documents                                                                                                                                                 |
| Category       | Public Access                                                                                                                                                                    |
| What was found | BlockPublicAcls=False, IgnorePublicAcls=False, BlockPublicPolicy=False, RestrictPublicBuckets=False                                                                              |
| Description    | The account-level or bucket-level S3 Block Public Access setting is not fully enabled. This safety net prevents accidental public exposure from any ACL or bucket policy change. |
| Impact         | A single misconfigured ACL or bucket policy can expose data to the entire internet with no account-level guardrail to prevent it.                                                |
| Fix            | Enable all 4 Block Public Access settings at the account level in S3 > Block Public Access. Also enable at the bucket level for each bucket.                                     |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.5   PCI-DSS Requirement 1.3                                                                                                                 |

**[S3-002] Bucket Publicly Accessible via ACL** → finvault-prod-customer-documents**CRITICAL**

|                |                                                                                                                                                               |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-customer-documents                                                                                                                              |
| Category       | Public Access                                                                                                                                                 |
| What was found | Public ACL grant found: AllUsers → READ                                                                                                                       |
| Description    | The bucket has a legacy ACL granting READ, WRITE, or FULL_CONTROL to AllUsers or AuthenticatedUsers groups, making objects accessible without authentication. |
| Impact         | Customer data, backups, and application files are exposed to the entire public internet. Direct GDPR Article 32 and PCI-DSS Requirement 3 violation.          |
| Fix            | Remove all public ACL grants. Switch to bucket policies for access control. Enable Block Public Access to prevent ACL-based public access.                    |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.5   GDPR Article 32                                                                                                      |

**[S3-003] Bucket Publicly Accessible via Policy** → finvault-prod-customer-documents**CRITICAL**

|                |                                                                                                                                                                                         |
|----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-customer-documents                                                                                                                                                        |
| Category       | Public Access                                                                                                                                                                           |
| What was found | Public policy statements: Action: s3:GetObject                                                                                                                                          |
| Description    | The bucket policy contains a statement with Principal: '*' and no restrictive conditions, allowing any unauthenticated request to access bucket objects.                                |
| Impact         | Public read or write access to bucket objects without any authentication. More dangerous than ACL exposure as policies can grant write access to anonymous users.                       |
| Fix            | Review and remove all Principal: '*' statements. If public access is intentional (e.g. static website), restrict to specific actions (s3:GetObject only) and enable CloudFront instead. |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.5   OWASP Cloud Security                                                                                                                           |

**[S3-001] Block Public Access Disabled** → finvault-prod-database-backups**CRITICAL**

|                |                                                                                                                                                                                  |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-database-backups                                                                                                                                                   |
| Category       | Public Access                                                                                                                                                                    |
| What was found | BlockPublicAcls=True, IgnorePublicAcls=True, BlockPublicPolicy=False, RestrictPublicBuckets=False                                                                                |
| Description    | The account-level or bucket-level S3 Block Public Access setting is not fully enabled. This safety net prevents accidental public exposure from any ACL or bucket policy change. |
| Impact         | A single misconfigured ACL or bucket policy can expose data to the entire internet with no account-level guardrail to prevent it.                                                |
| Fix            | Enable all 4 Block Public Access settings at the account level in S3 > Block Public Access. Also enable at the bucket level for each bucket.                                     |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.5   PCI-DSS Requirement 1.3                                                                                                                 |



**[S3-001] Block Public Access Disabled** → finvault-prod-invoices**CRITICAL**

|                |                                                                                                                                                                                  |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-invoices                                                                                                                                                           |
| Category       | Public Access                                                                                                                                                                    |
| What was found | BlockPublicAcls=True, IgnorePublicAcls=True, BlockPublicPolicy=False, RestrictPublicBuckets=False                                                                                |
| Description    | The account-level or bucket-level S3 Block Public Access setting is not fully enabled. This safety net prevents accidental public exposure from any ACL or bucket policy change. |
| Impact         | A single misconfigured ACL or bucket policy can expose data to the entire internet with no account-level guardrail to prevent it.                                                |
| Fix            | Enable all 4 Block Public Access settings at the account level in S3 > Block Public Access. Also enable at the bucket level for each bucket.                                     |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.5   PCI-DSS Requirement 1.3                                                                                                                 |

**[S3-001] Block Public Access Disabled** → finvault-staging-uploads**CRITICAL**

|                |                                                                                                                                                                                  |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-staging-uploads                                                                                                                                                         |
| Category       | Public Access                                                                                                                                                                    |
| What was found | BlockPublicAcls=False, IgnorePublicAcls=False, BlockPublicPolicy=True, RestrictPublicBuckets=True                                                                                |
| Description    | The account-level or bucket-level S3 Block Public Access setting is not fully enabled. This safety net prevents accidental public exposure from any ACL or bucket policy change. |
| Impact         | A single misconfigured ACL or bucket policy can expose data to the entire internet with no account-level guardrail to prevent it.                                                |
| Fix            | Enable all 4 Block Public Access settings at the account level in S3 > Block Public Access. Also enable at the bucket level for each bucket.                                     |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.5   PCI-DSS Requirement 1.3                                                                                                                 |

**[S3-002] Bucket Publicly Accessible via ACL** → finvault-staging-uploads**CRITICAL**

|                |                                                                                                                                                               |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-staging-uploads                                                                                                                                      |
| Category       | Public Access                                                                                                                                                 |
| What was found | Public ACL grant found: AuthenticatedUsers → READ                                                                                                             |
| Description    | The bucket has a legacy ACL granting READ, WRITE, or FULL_CONTROL to AllUsers or AuthenticatedUsers groups, making objects accessible without authentication. |
| Impact         | Customer data, backups, and application files are exposed to the entire public internet. Direct GDPR Article 32 and PCI-DSS Requirement 3 violation.          |
| Fix            | Remove all public ACL grants. Switch to bucket policies for access control. Enable Block Public Access to prevent ACL-based public access.                    |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.5   GDPR Article 32                                                                                                      |

**[S3-001] Block Public Access Disabled** → finvault-static-website**CRITICAL**

|                |                                                                                                                                                                                  |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-static-website                                                                                                                                                          |
| Category       | Public Access                                                                                                                                                                    |
| What was found | BlockPublicAcls=False, IgnorePublicAcls=False, BlockPublicPolicy=False, RestrictPublicBuckets=False                                                                              |
| Description    | The account-level or bucket-level S3 Block Public Access setting is not fully enabled. This safety net prevents accidental public exposure from any ACL or bucket policy change. |
| Impact         | A single misconfigured ACL or bucket policy can expose data to the entire internet with no account-level guardrail to prevent it.                                                |
| Fix            | Enable all 4 Block Public Access settings at the account level in S3 > Block Public Access. Also enable at the bucket level for each bucket.                                     |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.5   PCI-DSS Requirement 1.3                                                                                                                 |

**[S3-002] Bucket Publicly Accessible via ACL** → finvault-static-website**CRITICAL**

|                |                                                                                                                                                               |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-static-website                                                                                                                                       |
| Category       | Public Access                                                                                                                                                 |
| What was found | Public ACL grant found: AllUsers → READ                                                                                                                       |
| Description    | The bucket has a legacy ACL granting READ, WRITE, or FULL_CONTROL to AllUsers or AuthenticatedUsers groups, making objects accessible without authentication. |
| Impact         | Customer data, backups, and application files are exposed to the entire public internet. Direct GDPR Article 32 and PCI-DSS Requirement 3 violation.          |
| Fix            | Remove all public ACL grants. Switch to bucket policies for access control. Enable Block Public Access to prevent ACL-based public access.                    |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.5   GDPR Article 32                                                                                                      |

**[S3-003] Bucket Publicly Accessible via Policy** → finvault-static-website**CRITICAL**

|                |                                                                                                                                                                                         |
|----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-static-website                                                                                                                                                                 |
| Category       | Public Access                                                                                                                                                                           |
| What was found | Public policy statements: Action: s3:GetObject                                                                                                                                          |
| Description    | The bucket policy contains a statement with Principal: '*' and no restrictive conditions, allowing any unauthenticated request to access bucket objects.                                |
| Impact         | Public read or write access to bucket objects without any authentication. More dangerous than ACL exposure as policies can grant write access to anonymous users.                       |
| Fix            | Review and remove all Principal: '*' statements. If public access is intentional (e.g. static website), restrict to specific actions (s3:GetObject only) and enable CloudFront instead. |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.5   OWASP Cloud Security                                                                                                                           |

|                                                         |                                                                                                                                                                                |      |
|---------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| [S3-004] No Default Encryption → finvault-dev-test-data |                                                                                                                                                                                | HIGH |
| Bucket                                                  | finvault-dev-test-data                                                                                                                                                         |      |
| Category                                                | Encryption                                                                                                                                                                     |      |
| What was found                                          | No default encryption configured. Objects stored in plaintext.                                                                                                                 |      |
| Description                                             | The bucket does not have default server-side encryption configured. Objects uploaded without explicit encryption headers are stored in plaintext.                              |      |
| Impact                                                  | Data at rest is unencrypted. Violates PCI-DSS Requirement 3.4 (protect stored cardholder data) and GDPR Article 32 (appropriate technical measures). Required for SOC 2 CC6.1. |      |
| Fix                                                     | Enable default SSE-S3 encryption on the bucket (zero cost, zero performance impact). For sensitive data, use SSE-KMS with a Customer Managed Key for full audit trail.         |      |
| Reference                                               | AWS CIS Benchmark v1.5 — Control 2.1.1   PCI-DSS Requirement 3.4   SOC 2 CC6.1                                                                                                 |      |

|                                                                              |                                                                                                                                                                         |      |
|------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| [S3-005] HTTP Access Allowed (No HTTPS Enforcement) → finvault-dev-test-data |                                                                                                                                                                         | HIGH |
| Bucket                                                                       | finvault-dev-test-data                                                                                                                                                  |      |
| Category                                                                     | Encryption                                                                                                                                                              |      |
| What was found                                                               | No bucket policy HTTPS enforcement found.                                                                                                                               |      |
| Description                                                                  | The bucket policy does not contain a condition denying requests made over HTTP (aws:SecureTransport: false). Objects can be accessed over unencrypted HTTP connections. |      |
| Impact                                                                       | Data in transit is unencrypted and vulnerable to man-in-the-middle interception. Violates PCI-DSS Requirement 4.1 (encrypt transmission of cardholder data).            |      |
| Fix                                                                          | Add a bucket policy statement with Condition: {"Bool": {"aws:SecureTransport": "false"}} and Effect: Deny to enforce HTTPS-only access.                                 |      |
| Reference                                                                    | AWS CIS Benchmark v1.5 — Control 2.1.2   PCI-DSS Requirement 4.1                                                                                                        |      |

|                                                                         |                                                                                                                                                                                       |      |
|-------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| <b>[S3-006] Server Access Logging Disabled</b> → finvault-dev-test-data |                                                                                                                                                                                       | HIGH |
| Bucket                                                                  | finvault-dev-test-data                                                                                                                                                                |      |
| Category                                                                | Logging                                                                                                                                                                               |      |
| What was found                                                          | Server access logging is disabled.                                                                                                                                                    |      |
| Description                                                             | S3 server access logging is not enabled for this bucket. There is no record of who accessed, downloaded, modified, or deleted objects in this bucket.                                 |      |
| Impact                                                                  | Inability to detect data exfiltration, investigate breaches, or satisfy forensic requirements. Required for ISO 27001 A.12.4 and SOC 2 CC7.2 audit logging controls.                  |      |
| Fix                                                                     | Enable server access logging and route logs to a dedicated, write-only logging bucket. Set a minimum 90-day log retention policy. Consider Amazon Macie for sensitive data detection. |      |
| Reference                                                               | AWS CIS Benchmark v1.5 — Control 2.1.3   ISO 27001 A.12.4   PCI-DSS Requirement 10                                                                                                    |      |

|                                                              |                                                                                                                                                                                     |      |
|--------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| <b>[S3-007] Versioning Disabled</b> → finvault-dev-test-data |                                                                                                                                                                                     | HIGH |
| Bucket                                                       | finvault-dev-test-data                                                                                                                                                              |      |
| Category                                                     | Resilience                                                                                                                                                                          |      |
| What was found                                               | Versioning: Suspended                                                                                                                                                               |      |
| Description                                                  | S3 versioning is not enabled. When versioning is off, overwritten or deleted objects are permanently gone with no ability to recover previous versions.                             |      |
| Impact                                                       | Ransomware attacks that overwrite or delete objects result in permanent, unrecoverable data loss. No protection against accidental deletions or application bugs that corrupt data. |      |
| Fix                                                          | Enable S3 versioning on all buckets containing important data. Combine with lifecycle rules to expire old versions after 30-90 days to manage storage costs.                        |      |
| Reference                                                    | AWS Best Practices   NIST SP 800-53 CP-9   ISO 27001 A.12.3                                                                                                                         |      |

**[S3-008] MFA Delete Disabled** → finvault-dev-test-data**HIGH**

|                |                                                                                                                                                                        |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-dev-test-data                                                                                                                                                 |
| Category       | Resilience                                                                                                                                                             |
| What was found | MFA Delete: Disabled                                                                                                                                                   |
| Description    | MFA Delete is not enabled on this bucket. Without MFA Delete, any compromised IAM credential with s3:DeleteObject permission can permanently delete versioned objects. |
| Impact         | A compromised IAM key can irreversibly delete all versions of all objects in the bucket. No recovery possible after permanent deletion without MFA requirement.        |
| Fix            | Enable MFA Delete using the root account credentials and a hardware MFA device. This requires presenting MFA for any versioned object deletion operation.              |
| Reference      | AWS S3 Security Best Practices   PCI-DSS Requirement 8.3                                                                                                               |

**[S3-006] Server Access Logging Disabled** → finvault-prod-app-assets**HIGH**

|                |                                                                                                                                                                                       |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-app-assets                                                                                                                                                              |
| Category       | Logging                                                                                                                                                                               |
| What was found | Server access logging is disabled.                                                                                                                                                    |
| Description    | S3 server access logging is not enabled for this bucket. There is no record of who accessed, downloaded, modified, or deleted objects in this bucket.                                 |
| Impact         | Inability to detect data exfiltration, investigate breaches, or satisfy forensic requirements. Required for ISO 27001 A.12.4 and SOC 2 CC7.2 audit logging controls.                  |
| Fix            | Enable server access logging and route logs to a dedicated, write-only logging bucket. Set a minimum 90-day log retention policy. Consider Amazon Macie for sensitive data detection. |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.3   ISO 27001 A.12.4   PCI-DSS Requirement 10                                                                                                    |

**[S3-008] MFA Delete Disabled** → finvault-prod-app-assets**HIGH**

|                |                                                                                                                                                                        |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-app-assets                                                                                                                                               |
| Category       | Resilience                                                                                                                                                             |
| What was found | MFA Delete: Disabled                                                                                                                                                   |
| Description    | MFA Delete is not enabled on this bucket. Without MFA Delete, any compromised IAM credential with s3:DeleteObject permission can permanently delete versioned objects. |
| Impact         | A compromised IAM key can irreversibly delete all versions of all objects in the bucket. No recovery possible after permanent deletion without MFA requirement.        |
| Fix            | Enable MFA Delete using the root account credentials and a hardware MFA device. This requires presenting MFA for any versioned object deletion operation.              |
| Reference      | AWS S3 Security Best Practices   PCI-DSS Requirement 8.3                                                                                                               |

**[S3-008] MFA Delete Disabled** → finvault-prod-audit-logs**HIGH**

|                |                                                                                                                                                                        |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-audit-logs                                                                                                                                               |
| Category       | Resilience                                                                                                                                                             |
| What was found | MFA Delete: Disabled                                                                                                                                                   |
| Description    | MFA Delete is not enabled on this bucket. Without MFA Delete, any compromised IAM credential with s3:DeleteObject permission can permanently delete versioned objects. |
| Impact         | A compromised IAM key can irreversibly delete all versions of all objects in the bucket. No recovery possible after permanent deletion without MFA requirement.        |
| Fix            | Enable MFA Delete using the root account credentials and a hardware MFA device. This requires presenting MFA for any versioned object deletion operation.              |
| Reference      | AWS S3 Security Best Practices   PCI-DSS Requirement 8.3                                                                                                               |

|                                                                   |                                                                                                                                                                                |      |
|-------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| [S3-004] No Default Encryption → finvault-prod-customer-documents |                                                                                                                                                                                | HIGH |
| Bucket                                                            | finvault-prod-customer-documents                                                                                                                                               |      |
| Category                                                          | Encryption                                                                                                                                                                     |      |
| What was found                                                    | No default encryption configured. Objects stored in plaintext.                                                                                                                 |      |
| Description                                                       | The bucket does not have default server-side encryption configured. Objects uploaded without explicit encryption headers are stored in plaintext.                              |      |
| Impact                                                            | Data at rest is unencrypted. Violates PCI-DSS Requirement 3.4 (protect stored cardholder data) and GDPR Article 32 (appropriate technical measures). Required for SOC 2 CC6.1. |      |
| Fix                                                               | Enable default SSE-S3 encryption on the bucket (zero cost, zero performance impact). For sensitive data, use SSE-KMS with a Customer Managed Key for full audit trail.         |      |
| Reference                                                         | AWS CIS Benchmark v1.5 — Control 2.1.1   PCI-DSS Requirement 3.4   SOC 2 CC6.1                                                                                                 |      |

|                                                                                        |                                                                                                                                                                         |      |
|----------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| [S3-005] HTTP Access Allowed (No HTTPS Enforcement) → finvault-prod-customer-documents |                                                                                                                                                                         | HIGH |
| Bucket                                                                                 | finvault-prod-customer-documents                                                                                                                                        |      |
| Category                                                                               | Encryption                                                                                                                                                              |      |
| What was found                                                                         | No bucket policy — HTTP access is allowed by default.                                                                                                                   |      |
| Description                                                                            | The bucket policy does not contain a condition denying requests made over HTTP (aws:SecureTransport: false). Objects can be accessed over unencrypted HTTP connections. |      |
| Impact                                                                                 | Data in transit is unencrypted and vulnerable to man-in-the-middle interception. Violates PCI-DSS Requirement 4.1 (encrypt transmission of cardholder data).            |      |
| Fix                                                                                    | Add a bucket policy statement with Condition: {"Bool": {"aws:SecureTransport": "false"}} and Effect: Deny to enforce HTTPS-only access.                                 |      |
| Reference                                                                              | AWS CIS Benchmark v1.5 — Control 2.1.2   PCI-DSS Requirement 4.1                                                                                                        |      |



|                                                                            |                                                                                                                                                                                       |      |
|----------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| [S3-006] Server Access Logging Disabled → finvault-prod-customer-documents |                                                                                                                                                                                       | HIGH |
| Bucket                                                                     | finvault-prod-customer-documents                                                                                                                                                      |      |
| Category                                                                   | Logging                                                                                                                                                                               |      |
| What was found                                                             | Server access logging is disabled.                                                                                                                                                    |      |
| Description                                                                | S3 server access logging is not enabled for this bucket. There is no record of who accessed, downloaded, modified, or deleted objects in this bucket.                                 |      |
| Impact                                                                     | Inability to detect data exfiltration, investigate breaches, or satisfy forensic requirements. Required for ISO 27001 A.12.4 and SOC 2 CC7.2 audit logging controls.                  |      |
| Fix                                                                        | Enable server access logging and route logs to a dedicated, write-only logging bucket. Set a minimum 90-day log retention policy. Consider Amazon Macie for sensitive data detection. |      |
| Reference                                                                  | AWS CIS Benchmark v1.5 — Control 2.1.3   ISO 27001 A.12.4   PCI-DSS Requirement 10                                                                                                    |      |

|                                                                 |                                                                                                                                                                                     |      |
|-----------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| [S3-007] Versioning Disabled → finvault-prod-customer-documents |                                                                                                                                                                                     | HIGH |
| Bucket                                                          | finvault-prod-customer-documents                                                                                                                                                    |      |
| Category                                                        | Resilience                                                                                                                                                                          |      |
| What was found                                                  | Versioning: Never enabled                                                                                                                                                           |      |
| Description                                                     | S3 versioning is not enabled. When versioning is off, overwritten or deleted objects are permanently gone with no ability to recover previous versions.                             |      |
| Impact                                                          | Ransomware attacks that overwrite or delete objects result in permanent, unrecoverable data loss. No protection against accidental deletions or application bugs that corrupt data. |      |
| Fix                                                             | Enable S3 versioning on all buckets containing important data. Combine with lifecycle rules to expire old versions after 30-90 days to manage storage costs.                        |      |
| Reference                                                       | AWS Best Practices   NIST SP 800-53 CP-9   ISO 27001 A.12.3                                                                                                                         |      |

|                                                                        |                                                                                                                                                                        |      |
|------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| <b>[S3-008] MFA Delete Disabled</b> → finvault-prod-customer-documents |                                                                                                                                                                        | HIGH |
| Bucket                                                                 | finvault-prod-customer-documents                                                                                                                                       |      |
| Category                                                               | Resilience                                                                                                                                                             |      |
| What was found                                                         | MFA Delete: Disabled                                                                                                                                                   |      |
| Description                                                            | MFA Delete is not enabled on this bucket. Without MFA Delete, any compromised IAM credential with s3:DeleteObject permission can permanently delete versioned objects. |      |
| Impact                                                                 | A compromised IAM key can irreversibly delete all versions of all objects in the bucket. No recovery possible after permanent deletion without MFA requirement.        |      |
| Fix                                                                    | Enable MFA Delete using the root account credentials and a hardware MFA device. This requires presenting MFA for any versioned object deletion operation.              |      |
| Reference                                                              | AWS S3 Security Best Practices   PCI-DSS Requirement 8.3                                                                                                               |      |

|                                                                        |                                                                                                                                                                                |      |
|------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| <b>[S3-004] No Default Encryption</b> → finvault-prod-database-backups |                                                                                                                                                                                | HIGH |
| Bucket                                                                 | finvault-prod-database-backups                                                                                                                                                 |      |
| Category                                                               | Encryption                                                                                                                                                                     |      |
| What was found                                                         | No default encryption configured. Objects stored in plaintext.                                                                                                                 |      |
| Description                                                            | The bucket does not have default server-side encryption configured. Objects uploaded without explicit encryption headers are stored in plaintext.                              |      |
| Impact                                                                 | Data at rest is unencrypted. Violates PCI-DSS Requirement 3.4 (protect stored cardholder data) and GDPR Article 32 (appropriate technical measures). Required for SOC 2 CC6.1. |      |
| Fix                                                                    | Enable default SSE-S3 encryption on the bucket (zero cost, zero performance impact). For sensitive data, use SSE-KMS with a Customer Managed Key for full audit trail.         |      |
| Reference                                                              | AWS CIS Benchmark v1.5 — Control 2.1.1   PCI-DSS Requirement 3.4   SOC 2 CC6.1                                                                                                 |      |

**[S3-005] HTTP Access Allowed (No HTTPS Enforcement)** → finvault-prod-database-backups**HIGH**

|                |                                                                                                                                                                         |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-database-backups                                                                                                                                          |
| Category       | Encryption                                                                                                                                                              |
| What was found | No HTTPS-enforcement deny rule in bucket policy. HTTP access is allowed.                                                                                                |
| Description    | The bucket policy does not contain a condition denying requests made over HTTP (aws:SecureTransport: false). Objects can be accessed over unencrypted HTTP connections. |
| Impact         | Data in transit is unencrypted and vulnerable to man-in-the-middle interception. Violates PCI-DSS Requirement 4.1 (encrypt transmission of cardholder data).            |
| Fix            | Add a bucket policy statement with Condition: {"Bool": {"aws:SecureTransport": "false"}} and Effect: Deny to enforce HTTPS-only access.                                 |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.2   PCI-DSS Requirement 4.1                                                                                                        |

**[S3-006] Server Access Logging Disabled** → finvault-prod-database-backups**HIGH**

|                |                                                                                                                                                                                       |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-database-backups                                                                                                                                                        |
| Category       | Logging                                                                                                                                                                               |
| What was found | Server access logging is disabled.                                                                                                                                                    |
| Description    | S3 server access logging is not enabled for this bucket. There is no record of who accessed, downloaded, modified, or deleted objects in this bucket.                                 |
| Impact         | Inability to detect data exfiltration, investigate breaches, or satisfy forensic requirements. Required for ISO 27001 A.12.4 and SOC 2 CC7.2 audit logging controls.                  |
| Fix            | Enable server access logging and route logs to a dedicated, write-only logging bucket. Set a minimum 90-day log retention policy. Consider Amazon Macie for sensitive data detection. |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.3   ISO 27001 A.12.4   PCI-DSS Requirement 10                                                                                                    |

**[S3-008] MFA Delete Disabled** → finvault-prod-database-backups**HIGH**

|                |                                                                                                                                                                        |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-database-backups                                                                                                                                         |
| Category       | Resilience                                                                                                                                                             |
| What was found | MFA Delete: Disabled                                                                                                                                                   |
| Description    | MFA Delete is not enabled on this bucket. Without MFA Delete, any compromised IAM credential with s3:DeleteObject permission can permanently delete versioned objects. |
| Impact         | A compromised IAM key can irreversibly delete all versions of all objects in the bucket. No recovery possible after permanent deletion without MFA requirement.        |
| Fix            | Enable MFA Delete using the root account credentials and a hardware MFA device. This requires presenting MFA for any versioned object deletion operation.              |
| Reference      | AWS S3 Security Best Practices   PCI-DSS Requirement 8.3                                                                                                               |

**[S3-004] No Default Encryption** → finvault-prod-invoices**HIGH**

|                |                                                                                                                                                                                |
|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-invoices                                                                                                                                                         |
| Category       | Encryption                                                                                                                                                                     |
| What was found | No default encryption configured. Objects stored in plaintext.                                                                                                                 |
| Description    | The bucket does not have default server-side encryption configured. Objects uploaded without explicit encryption headers are stored in plaintext.                              |
| Impact         | Data at rest is unencrypted. Violates PCI-DSS Requirement 3.4 (protect stored cardholder data) and GDPR Article 32 (appropriate technical measures). Required for SOC 2 CC6.1. |
| Fix            | Enable default SSE-S3 encryption on the bucket (zero cost, zero performance impact). For sensitive data, use SSE-KMS with a Customer Managed Key for full audit trail.         |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.1   PCI-DSS Requirement 3.4   SOC 2 CC6.1                                                                                                 |

**[S3-005] HTTP Access Allowed (No HTTPS Enforcement)** → finvault-prod-invoices**HIGH**

|                |                                                                                                                                                                         |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-invoices                                                                                                                                                  |
| Category       | Encryption                                                                                                                                                              |
| What was found | No HTTPS-enforcement deny rule in bucket policy.                                                                                                                        |
| Description    | The bucket policy does not contain a condition denying requests made over HTTP (aws:SecureTransport: false). Objects can be accessed over unencrypted HTTP connections. |
| Impact         | Data in transit is unencrypted and vulnerable to man-in-the-middle interception. Violates PCI-DSS Requirement 4.1 (encrypt transmission of cardholder data).            |
| Fix            | Add a bucket policy statement with Condition: {"Bool": {"aws:SecureTransport": "false"}} and Effect: Deny to enforce HTTPS-only access.                                 |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.2   PCI-DSS Requirement 4.1                                                                                                        |

**[S3-006] Server Access Logging Disabled** → finvault-prod-invoices**HIGH**

|                |                                                                                                                                                                                       |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-invoices                                                                                                                                                                |
| Category       | Logging                                                                                                                                                                               |
| What was found | Server access logging is disabled.                                                                                                                                                    |
| Description    | S3 server access logging is not enabled for this bucket. There is no record of who accessed, downloaded, modified, or deleted objects in this bucket.                                 |
| Impact         | Inability to detect data exfiltration, investigate breaches, or satisfy forensic requirements. Required for ISO 27001 A.12.4 and SOC 2 CC7.2 audit logging controls.                  |
| Fix            | Enable server access logging and route logs to a dedicated, write-only logging bucket. Set a minimum 90-day log retention policy. Consider Amazon Macie for sensitive data detection. |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.3   ISO 27001 A.12.4   PCI-DSS Requirement 10                                                                                                    |

**[S3-007] Versioning Disabled** → finvault-prod-invoices

HIGH

|                |                                                                                                                                                                                     |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-invoices                                                                                                                                                              |
| Category       | Resilience                                                                                                                                                                          |
| What was found | Versioning: Never enabled                                                                                                                                                           |
| Description    | S3 versioning is not enabled. When versioning is off, overwritten or deleted objects are permanently gone with no ability to recover previous versions.                             |
| Impact         | Ransomware attacks that overwrite or delete objects result in permanent, unrecoverable data loss. No protection against accidental deletions or application bugs that corrupt data. |
| Fix            | Enable S3 versioning on all buckets containing important data. Combine with lifecycle rules to expire old versions after 30-90 days to manage storage costs.                        |
| Reference      | AWS Best Practices   NIST SP 800-53 CP-9   ISO 27001 A.12.3                                                                                                                         |

**[S3-008] MFA Delete Disabled** → finvault-prod-invoices

HIGH

|                |                                                                                                                                                                        |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-invoices                                                                                                                                                 |
| Category       | Resilience                                                                                                                                                             |
| What was found | MFA Delete: Disabled                                                                                                                                                   |
| Description    | MFA Delete is not enabled on this bucket. Without MFA Delete, any compromised IAM credential with s3:DeleteObject permission can permanently delete versioned objects. |
| Impact         | A compromised IAM key can irreversibly delete all versions of all objects in the bucket. No recovery possible after permanent deletion without MFA requirement.        |
| Fix            | Enable MFA Delete using the root account credentials and a hardware MFA device. This requires presenting MFA for any versioned object deletion operation.              |
| Reference      | AWS S3 Security Best Practices   PCI-DSS Requirement 8.3                                                                                                               |

|                                                           |                                                                                                                                                                                |      |
|-----------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| [S3-004] No Default Encryption → finvault-staging-uploads |                                                                                                                                                                                | HIGH |
| Bucket                                                    | finvault-staging-uploads                                                                                                                                                       |      |
| Category                                                  | Encryption                                                                                                                                                                     |      |
| What was found                                            | No default encryption configured. Objects stored in plaintext.                                                                                                                 |      |
| Description                                               | The bucket does not have default server-side encryption configured. Objects uploaded without explicit encryption headers are stored in plaintext.                              |      |
| Impact                                                    | Data at rest is unencrypted. Violates PCI-DSS Requirement 3.4 (protect stored cardholder data) and GDPR Article 32 (appropriate technical measures). Required for SOC 2 CC6.1. |      |
| Fix                                                       | Enable default SSE-S3 encryption on the bucket (zero cost, zero performance impact). For sensitive data, use SSE-KMS with a Customer Managed Key for full audit trail.         |      |
| Reference                                                 | AWS CIS Benchmark v1.5 — Control 2.1.1   PCI-DSS Requirement 3.4   SOC 2 CC6.1                                                                                                 |      |

|                                                                                |                                                                                                                                                                         |      |
|--------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| [S3-005] HTTP Access Allowed (No HTTPS Enforcement) → finvault-staging-uploads |                                                                                                                                                                         | HIGH |
| Bucket                                                                         | finvault-staging-uploads                                                                                                                                                |      |
| Category                                                                       | Encryption                                                                                                                                                              |      |
| What was found                                                                 | No HTTPS-enforcement deny rule in bucket policy.                                                                                                                        |      |
| Description                                                                    | The bucket policy does not contain a condition denying requests made over HTTP (aws:SecureTransport: false). Objects can be accessed over unencrypted HTTP connections. |      |
| Impact                                                                         | Data in transit is unencrypted and vulnerable to man-in-the-middle interception. Violates PCI-DSS Requirement 4.1 (encrypt transmission of cardholder data).            |      |
| Fix                                                                            | Add a bucket policy statement with Condition: {"Bool": {"aws:SecureTransport": "false"}} and Effect: Deny to enforce HTTPS-only access.                                 |      |
| Reference                                                                      | AWS CIS Benchmark v1.5 — Control 2.1.2   PCI-DSS Requirement 4.1                                                                                                        |      |

|                                                                    |                                                                                                                                                                                       |      |
|--------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| [S3-006] Server Access Logging Disabled → finvault-staging-uploads |                                                                                                                                                                                       | HIGH |
| Bucket                                                             | finvault-staging-uploads                                                                                                                                                              |      |
| Category                                                           | Logging                                                                                                                                                                               |      |
| What was found                                                     | Server access logging is disabled.                                                                                                                                                    |      |
| Description                                                        | S3 server access logging is not enabled for this bucket. There is no record of who accessed, downloaded, modified, or deleted objects in this bucket.                                 |      |
| Impact                                                             | Inability to detect data exfiltration, investigate breaches, or satisfy forensic requirements. Required for ISO 27001 A.12.4 and SOC 2 CC7.2 audit logging controls.                  |      |
| Fix                                                                | Enable server access logging and route logs to a dedicated, write-only logging bucket. Set a minimum 90-day log retention policy. Consider Amazon Macie for sensitive data detection. |      |
| Reference                                                          | AWS CIS Benchmark v1.5 — Control 2.1.3   ISO 27001 A.12.4   PCI-DSS Requirement 10                                                                                                    |      |

|                                                         |                                                                                                                                                                                     |      |
|---------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| [S3-007] Versioning Disabled → finvault-staging-uploads |                                                                                                                                                                                     | HIGH |
| Bucket                                                  | finvault-staging-uploads                                                                                                                                                            |      |
| Category                                                | Resilience                                                                                                                                                                          |      |
| What was found                                          | Versioning: Never enabled                                                                                                                                                           |      |
| Description                                             | S3 versioning is not enabled. When versioning is off, overwritten or deleted objects are permanently gone with no ability to recover previous versions.                             |      |
| Impact                                                  | Ransomware attacks that overwrite or delete objects result in permanent, unrecoverable data loss. No protection against accidental deletions or application bugs that corrupt data. |      |
| Fix                                                     | Enable S3 versioning on all buckets containing important data. Combine with lifecycle rules to expire old versions after 30-90 days to manage storage costs.                        |      |
| Reference                                               | AWS Best Practices   NIST SP 800-53 CP-9   ISO 27001 A.12.3                                                                                                                         |      |



**[S3-008] MFA Delete Disabled** → finvault-staging-uploads

HIGH

|                |                                                                                                                                                                        |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-staging-uploads                                                                                                                                               |
| Category       | Resilience                                                                                                                                                             |
| What was found | MFA Delete: Disabled                                                                                                                                                   |
| Description    | MFA Delete is not enabled on this bucket. Without MFA Delete, any compromised IAM credential with s3:DeleteObject permission can permanently delete versioned objects. |
| Impact         | A compromised IAM key can irreversibly delete all versions of all objects in the bucket. No recovery possible after permanent deletion without MFA requirement.        |
| Fix            | Enable MFA Delete using the root account credentials and a hardware MFA device. This requires presenting MFA for any versioned object deletion operation.              |
| Reference      | AWS S3 Security Best Practices   PCI-DSS Requirement 8.3                                                                                                               |

**[S3-005] HTTP Access Allowed (No HTTPS Enforcement)** → finvault-static-website

HIGH

|                |                                                                                                                                                                         |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-static-website                                                                                                                                                 |
| Category       | Encryption                                                                                                                                                              |
| What was found | No HTTPS-enforcement deny rule in bucket policy.                                                                                                                        |
| Description    | The bucket policy does not contain a condition denying requests made over HTTP (aws:SecureTransport: false). Objects can be accessed over unencrypted HTTP connections. |
| Impact         | Data in transit is unencrypted and vulnerable to man-in-the-middle interception. Violates PCI-DSS Requirement 4.1 (encrypt transmission of cardholder data).            |
| Fix            | Add a bucket policy statement with Condition: {"Bool": {"aws:SecureTransport": "false"}} and Effect: Deny to enforce HTTPS-only access.                                 |
| Reference      | AWS CIS Benchmark v1.5 — Control 2.1.2   PCI-DSS Requirement 4.1                                                                                                        |

|                                                                          |                                                                                                                                                                                       |      |
|--------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| <b>[S3-006] Server Access Logging Disabled</b> → finvault-static-website |                                                                                                                                                                                       | HIGH |
| Bucket                                                                   | finvault-static-website                                                                                                                                                               |      |
| Category                                                                 | Logging                                                                                                                                                                               |      |
| What was found                                                           | Server access logging is disabled.                                                                                                                                                    |      |
| Description                                                              | S3 server access logging is not enabled for this bucket. There is no record of who accessed, downloaded, modified, or deleted objects in this bucket.                                 |      |
| Impact                                                                   | Inability to detect data exfiltration, investigate breaches, or satisfy forensic requirements. Required for ISO 27001 A.12.4 and SOC 2 CC7.2 audit logging controls.                  |      |
| Fix                                                                      | Enable server access logging and route logs to a dedicated, write-only logging bucket. Set a minimum 90-day log retention policy. Consider Amazon Macie for sensitive data detection. |      |
| Reference                                                                | AWS CIS Benchmark v1.5 — Control 2.1.3   ISO 27001 A.12.4   PCI-DSS Requirement 10                                                                                                    |      |

|                                                               |                                                                                                                                                                                     |      |
|---------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| <b>[S3-007] Versioning Disabled</b> → finvault-static-website |                                                                                                                                                                                     | HIGH |
| Bucket                                                        | finvault-static-website                                                                                                                                                             |      |
| Category                                                      | Resilience                                                                                                                                                                          |      |
| What was found                                                | Versioning: Never enabled                                                                                                                                                           |      |
| Description                                                   | S3 versioning is not enabled. When versioning is off, overwritten or deleted objects are permanently gone with no ability to recover previous versions.                             |      |
| Impact                                                        | Ransomware attacks that overwrite or delete objects result in permanent, unrecoverable data loss. No protection against accidental deletions or application bugs that corrupt data. |      |
| Fix                                                           | Enable S3 versioning on all buckets containing important data. Combine with lifecycle rules to expire old versions after 30-90 days to manage storage costs.                        |      |
| Reference                                                     | AWS Best Practices   NIST SP 800-53 CP-9   ISO 27001 A.12.3                                                                                                                         |      |

**[S3-008] MFA Delete Disabled** → finvault-static-website**HIGH**

|                |                                                                                                                                                                        |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-static-website                                                                                                                                                |
| Category       | Resilience                                                                                                                                                             |
| What was found | MFA Delete: Disabled                                                                                                                                                   |
| Description    | MFA Delete is not enabled on this bucket. Without MFA Delete, any compromised IAM credential with s3:DeleteObject permission can permanently delete versioned objects. |
| Impact         | A compromised IAM key can irreversibly delete all versions of all objects in the bucket. No recovery possible after permanent deletion without MFA requirement.        |
| Fix            | Enable MFA Delete using the root account credentials and a hardware MFA device. This requires presenting MFA for any versioned object deletion operation.              |
| Reference      | AWS S3 Security Best Practices   PCI-DSS Requirement 8.3                                                                                                               |

**[S3-010] No Lifecycle Policy Configured** → finvault-dev-test-data**MEDIUM**

|                |                                                                                                                                                                                                    |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-dev-test-data                                                                                                                                                                             |
| Category       | Data Governance                                                                                                                                                                                    |
| What was found | No lifecycle policy configured. Objects retained indefinitely.                                                                                                                                     |
| Description    | No S3 lifecycle policy is configured for this bucket. Objects are retained indefinitely with no automated tiering, archival, or deletion of old data.                                              |
| Impact         | Old and unnecessary data accumulates indefinitely, increasing storage costs and the potential blast radius of a breach. Uncontrolled data retention may violate GDPR data minimisation principles. |
| Fix            | Create an S3 lifecycle policy to: transition objects to S3-IA after 30 days, Glacier after 90 days, and delete after your data retention policy period (e.g. 1 or 7 years).                        |
| Reference      | GDPR Article 5(1)(e) — Storage Limitation   ISO 27001 A.8.3   AWS Cost Optimisation                                                                                                                |

**[S3-009] Cross-Account Access in Bucket Policy** → finvault-prod-app-assets

MEDIUM

|                |                                                                                                                                                                                     |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-app-assets                                                                                                                                                            |
| Category       | Access Control                                                                                                                                                                      |
| What was found | Cross-account access granted to account(s): 987654321098                                                                                                                            |
| Description    | The bucket policy grants access to IAM principals from external AWS account IDs. This means third parties outside your AWS organization can access this bucket.                     |
| Impact         | Supply chain risk — if the third-party AWS account is compromised, the attacker gains access to your bucket. Unauthorised cross-account access is a common data breach vector.      |
| Fix            | Audit all cross-account principals in the bucket policy. Remove any that are no longer needed. For required third-party access, use AWS RAM or pre-signed URLs with expiry instead. |
| Reference      | AWS S3 Security Best Practices   ISO 27001 A.15 (Supplier Relationships)                                                                                                            |

**[S3-010] No Lifecycle Policy Configured** → finvault-prod-customer-documents

MEDIUM

|                |                                                                                                                                                                                                    |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bucket         | finvault-prod-customer-documents                                                                                                                                                                   |
| Category       | Data Governance                                                                                                                                                                                    |
| What was found | No lifecycle policy configured. Objects retained indefinitely.                                                                                                                                     |
| Description    | No S3 lifecycle policy is configured for this bucket. Objects are retained indefinitely with no automated tiering, archival, or deletion of old data.                                              |
| Impact         | Old and unnecessary data accumulates indefinitely, increasing storage costs and the potential blast radius of a breach. Uncontrolled data retention may violate GDPR data minimisation principles. |
| Fix            | Create an S3 lifecycle policy to: transition objects to S3-IA after 30 days, Glacier after 90 days, and delete after your data retention policy period (e.g. 1 or 7 years).                        |
| Reference      | GDPR Article 5(1)(e) — Storage Limitation   ISO 27001 A.8.3   AWS Cost Optimisation                                                                                                                |

|                                                                                 |                                                                                                                                                                                                    |        |
|---------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| <b>[S3-010] No Lifecycle Policy Configured</b> → finvault-prod-database-backups |                                                                                                                                                                                                    | MEDIUM |
| Bucket                                                                          | finvault-prod-database-backups                                                                                                                                                                     |        |
| Category                                                                        | Data Governance                                                                                                                                                                                    |        |
| What was found                                                                  | No lifecycle policy configured. Objects retained indefinitely.                                                                                                                                     |        |
| Description                                                                     | No S3 lifecycle policy is configured for this bucket. Objects are retained indefinitely with no automated tiering, archival, or deletion of old data.                                              |        |
| Impact                                                                          | Old and unnecessary data accumulates indefinitely, increasing storage costs and the potential blast radius of a breach. Uncontrolled data retention may violate GDPR data minimisation principles. |        |
| Fix                                                                             | Create an S3 lifecycle policy to: transition objects to S3-IA after 30 days, Glacier after 90 days, and delete after your data retention policy period (e.g. 1 or 7 years).                        |        |
| Reference                                                                       | GDPR Article 5(1)(e) — Storage Limitation   ISO 27001 A.8.3   AWS Cost Optimisation                                                                                                                |        |

|                                                                                |                                                                                                                                                                                     |        |
|--------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| <b>[S3-009] Cross-Account Access in Bucket Policy</b> → finvault-prod-invoices |                                                                                                                                                                                     | MEDIUM |
| Bucket                                                                         | finvault-prod-invoices                                                                                                                                                              |        |
| Category                                                                       | Access Control                                                                                                                                                                      |        |
| What was found                                                                 | Cross-account access granted to account(s): 111222333444                                                                                                                            |        |
| Description                                                                    | The bucket policy grants access to IAM principals from external AWS account IDs. This means third parties outside your AWS organization can access this bucket.                     |        |
| Impact                                                                         | Supply chain risk — if the third-party AWS account is compromised, the attacker gains access to your bucket. Unauthorised cross-account access is a common data breach vector.      |        |
| Fix                                                                            | Audit all cross-account principals in the bucket policy. Remove any that are no longer needed. For required third-party access, use AWS RAM or pre-signed URLs with expiry instead. |        |
| Reference                                                                      | AWS S3 Security Best Practices   ISO 27001 A.15 (Supplier Relationships)                                                                                                            |        |

|                                                                         |                                                                                                                                                                                                    |        |
|-------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| <b>[S3-010] No Lifecycle Policy Configured</b> → finvault-prod-invoices |                                                                                                                                                                                                    | MEDIUM |
| Bucket                                                                  | finvault-prod-invoices                                                                                                                                                                             |        |
| Category                                                                | Data Governance                                                                                                                                                                                    |        |
| What was found                                                          | No lifecycle policy configured. Objects retained indefinitely.                                                                                                                                     |        |
| Description                                                             | No S3 lifecycle policy is configured for this bucket. Objects are retained indefinitely with no automated tiering, archival, or deletion of old data.                                              |        |
| Impact                                                                  | Old and unnecessary data accumulates indefinitely, increasing storage costs and the potential blast radius of a breach. Uncontrolled data retention may violate GDPR data minimisation principles. |        |
| Fix                                                                     | Create an S3 lifecycle policy to: transition objects to S3-IA after 30 days, Glacier after 90 days, and delete after your data retention policy period (e.g. 1 or 7 years).                        |        |
| Reference                                                               | GDPR Article 5(1)(e) — Storage Limitation   ISO 27001 A.8.3   AWS Cost Optimisation                                                                                                                |        |

|                                                                           |                                                                                                                                                                                                    |        |
|---------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| <b>[S3-010] No Lifecycle Policy Configured</b> → finvault-staging-uploads |                                                                                                                                                                                                    | MEDIUM |
| Bucket                                                                    | finvault-staging-uploads                                                                                                                                                                           |        |
| Category                                                                  | Data Governance                                                                                                                                                                                    |        |
| What was found                                                            | No lifecycle policy configured. Objects retained indefinitely.                                                                                                                                     |        |
| Description                                                               | No S3 lifecycle policy is configured for this bucket. Objects are retained indefinitely with no automated tiering, archival, or deletion of old data.                                              |        |
| Impact                                                                    | Old and unnecessary data accumulates indefinitely, increasing storage costs and the potential blast radius of a breach. Uncontrolled data retention may violate GDPR data minimisation principles. |        |
| Fix                                                                       | Create an S3 lifecycle policy to: transition objects to S3-IA after 30 days, Glacier after 90 days, and delete after your data retention policy period (e.g. 1 or 7 years).                        |        |
| Reference                                                                 | GDPR Article 5(1)(e) — Storage Limitation   ISO 27001 A.8.3   AWS Cost Optimisation                                                                                                                |        |

|                                                                   |                                                                                                                                                                                                    |        |
|-------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| [S3-010] No Lifecycle Policy Configured → finvault-static-website |                                                                                                                                                                                                    | MEDIUM |
| Bucket                                                            | finvault-static-website                                                                                                                                                                            |        |
| Category                                                          | Data Governance                                                                                                                                                                                    |        |
| What was found                                                    | No lifecycle policy configured. Objects retained indefinitely.                                                                                                                                     |        |
| Description                                                       | No S3 lifecycle policy is configured for this bucket. Objects are retained indefinitely with no automated tiering, archival, or deletion of old data.                                              |        |
| Impact                                                            | Old and unnecessary data accumulates indefinitely, increasing storage costs and the potential blast radius of a breach. Uncontrolled data retention may violate GDPR data minimisation principles. |        |
| Fix                                                               | Create an S3 lifecycle policy to: transition objects to S3-IA after 30 days, Glacier after 90 days, and delete after your data retention policy period (e.g. 1 or 7 years).                        |        |
| Reference                                                         | GDPR Article 5(1)(e) — Storage Limitation   ISO 27001 A.8.3   AWS Cost Optimisation                                                                                                                |        |

5. Remediation Roadmap

|                                                                                         |          |
|-----------------------------------------------------------------------------------------|----------|
| Immediate (0–7 days)                                                                    | CRITICAL |
| → S3-001: Block Public Access Disabled (finvault-dev-test-data)                         |          |
| → S3-003: Bucket Publicly Accessible via Policy (finvault-dev-test-data)                |          |
| → S3-001: Block Public Access Disabled (finvault-prod-customer-documents)               |          |
| → S3-002: Bucket Publicly Accessible via ACL (finvault-prod-customer-documents)         |          |
| → S3-003: Bucket Publicly Accessible via Policy (finvault-prod-customer-documents)      |          |
| → S3-001: Block Public Access Disabled (finvault-prod-database-backups)                 |          |
| → S3-001: Block Public Access Disabled (finvault-prod-invoices)                         |          |
| → S3-001: Block Public Access Disabled (finvault-staging-uploads)                       |          |
| → S3-002: Bucket Publicly Accessible via ACL (finvault-staging-uploads)                 |          |
| → S3-001: Block Public Access Disabled (finvault-static-website)                        |          |
| → S3-002: Bucket Publicly Accessible via ACL (finvault-static-website)                  |          |
| → S3-003: Bucket Publicly Accessible via Policy (finvault-static-website)               |          |
| Short-term (7–30 days)                                                                  | HIGH     |
| → S3-004: No Default Encryption (finvault-dev-test-data)                                |          |
| → S3-005: HTTP Access Allowed (No HTTPS Enforcement) (finvault-dev-test-data)           |          |
| → S3-006: Server Access Logging Disabled (finvault-dev-test-data)                       |          |
| → S3-007: Versioning Disabled (finvault-dev-test-data)                                  |          |
| → S3-008: MFA Delete Disabled (finvault-dev-test-data)                                  |          |
| → S3-006: Server Access Logging Disabled (finvault-prod-app-assets)                     |          |
| → S3-008: MFA Delete Disabled (finvault-prod-app-assets)                                |          |
| → S3-008: MFA Delete Disabled (finvault-prod-audit-logs)                                |          |
| → S3-004: No Default Encryption (finvault-prod-customer-documents)                      |          |
| → S3-005: HTTP Access Allowed (No HTTPS Enforcement) (finvault-prod-customer-documents) |          |
| → S3-006: Server Access Logging Disabled (finvault-prod-customer-documents)             |          |



|                                                                                               |
|-----------------------------------------------------------------------------------------------|
| → <b>S3-007</b> : Versioning Disabled (finvault-prod-customer-documents)                      |
| → <b>S3-008</b> : MFA Delete Disabled (finvault-prod-customer-documents)                      |
| → <b>S3-004</b> : No Default Encryption (finvault-prod-database-backups)                      |
| → <b>S3-005</b> : HTTP Access Allowed (No HTTPS Enforcement) (finvault-prod-database-backups) |
| → <b>S3-006</b> : Server Access Logging Disabled (finvault-prod-database-backups)             |
| → <b>S3-008</b> : MFA Delete Disabled (finvault-prod-database-backups)                        |
| → <b>S3-004</b> : No Default Encryption (finvault-prod-invoices)                              |
| → <b>S3-005</b> : HTTP Access Allowed (No HTTPS Enforcement) (finvault-prod-invoices)         |
| → <b>S3-006</b> : Server Access Logging Disabled (finvault-prod-invoices)                     |
| → <b>S3-007</b> : Versioning Disabled (finvault-prod-invoices)                                |
| → <b>S3-008</b> : MFA Delete Disabled (finvault-prod-invoices)                                |
| → <b>S3-004</b> : No Default Encryption (finvault-staging-uploads)                            |
| → <b>S3-005</b> : HTTP Access Allowed (No HTTPS Enforcement) (finvault-staging-uploads)       |
| → <b>S3-006</b> : Server Access Logging Disabled (finvault-staging-uploads)                   |
| → <b>S3-007</b> : Versioning Disabled (finvault-staging-uploads)                              |
| → <b>S3-008</b> : MFA Delete Disabled (finvault-staging-uploads)                              |
| → <b>S3-005</b> : HTTP Access Allowed (No HTTPS Enforcement) (finvault-static-website)        |
| → <b>S3-006</b> : Server Access Logging Disabled (finvault-static-website)                    |
| → <b>S3-007</b> : Versioning Disabled (finvault-static-website)                               |
| → <b>S3-008</b> : MFA Delete Disabled (finvault-static-website)                               |

| Medium-term (30–90 days)                                                            | MEDIUM |
|-------------------------------------------------------------------------------------|--------|
| → <b>S3-010</b> : No Lifecycle Policy Configured (finvault-dev-test-data)           |        |
| → <b>S3-009</b> : Cross-Account Access in Bucket Policy (finvault-prod-app-assets)  |        |
| → <b>S3-010</b> : No Lifecycle Policy Configured (finvault-prod-customer-documents) |        |
| → <b>S3-010</b> : No Lifecycle Policy Configured (finvault-prod-database-backups)   |        |
| → <b>S3-009</b> : Cross-Account Access in Bucket Policy (finvault-prod-invoices)    |        |
| → <b>S3-010</b> : No Lifecycle Policy Configured (finvault-prod-invoices)           |        |
| → <b>S3-010</b> : No Lifecycle Policy Configured (finvault-staging-uploads)         |        |

→ **S3-010:** No Lifecycle Policy Configured (finvault-static-website)

6. Appendix — Check Definitions

| Check ID | Name                                       | Severity | Category        | Reference                                                                           |
|----------|--------------------------------------------|----------|-----------------|-------------------------------------------------------------------------------------|
| S3-001   | Block Public Access Disabled               | CRITICAL | Public Access   | AWS CIS Benchmark v1.5 — Control 2.1.5   PCI-DSS Requirement 1.3                    |
| S3-002   | Bucket Publicly Accessible via ACL         | CRITICAL | Public Access   | AWS CIS Benchmark v1.5 — Control 2.1.5   GDPR Article 32                            |
| S3-003   | Bucket Publicly Accessible via Policy      | CRITICAL | Public Access   | AWS CIS Benchmark v1.5 — Control 2.1.5   OWASP Cloud Security                       |
| S3-004   | No Default Encryption                      | HIGH     | Encryption      | AWS CIS Benchmark v1.5 — Control 2.1.1   PCI-DSS Requirement 3.4   SOC 2 CC6.1      |
| S3-005   | HTTP Access Allowed (No HTTPS Enforcement) | HIGH     | Encryption      | AWS CIS Benchmark v1.5 — Control 2.1.2   PCI-DSS Requirement 4.1                    |
| S3-006   | Server Access Logging Disabled             | HIGH     | Logging         | AWS CIS Benchmark v1.5 — Control 2.1.3   ISO 27001 A.12.4   PCI-DSS Requirement 10  |
| S3-007   | Versioning Disabled                        | HIGH     | Resilience      | AWS Best Practices   NIST SP 800-53 CP-9   ISO 27001 A.12.3                         |
| S3-008   | MFA Delete Disabled                        | HIGH     | Resilience      | AWS S3 Security Best Practices   PCI-DSS Requirement 8.3                            |
| S3-009   | Cross-Account Access in Bucket Policy      | MEDIUM   | Access Control  | AWS S3 Security Best Practices   ISO 27001 A.15 (Supplier Relationships)            |
| S3-010   | No Lifecycle Policy Configured             | MEDIUM   | Data Governance | GDPR Article 5(1)(e) — Storage Limitation   ISO 27001 A.8.3   AWS Cost Optimisation |

This report was prepared by Your Name (Cloud Security Consultant) on June 19, 2026. All findings reflect the state of the AWS S3 environment at the time of scan. Remediation should be verified with a re-scan. Contact: hello@yoursite.com